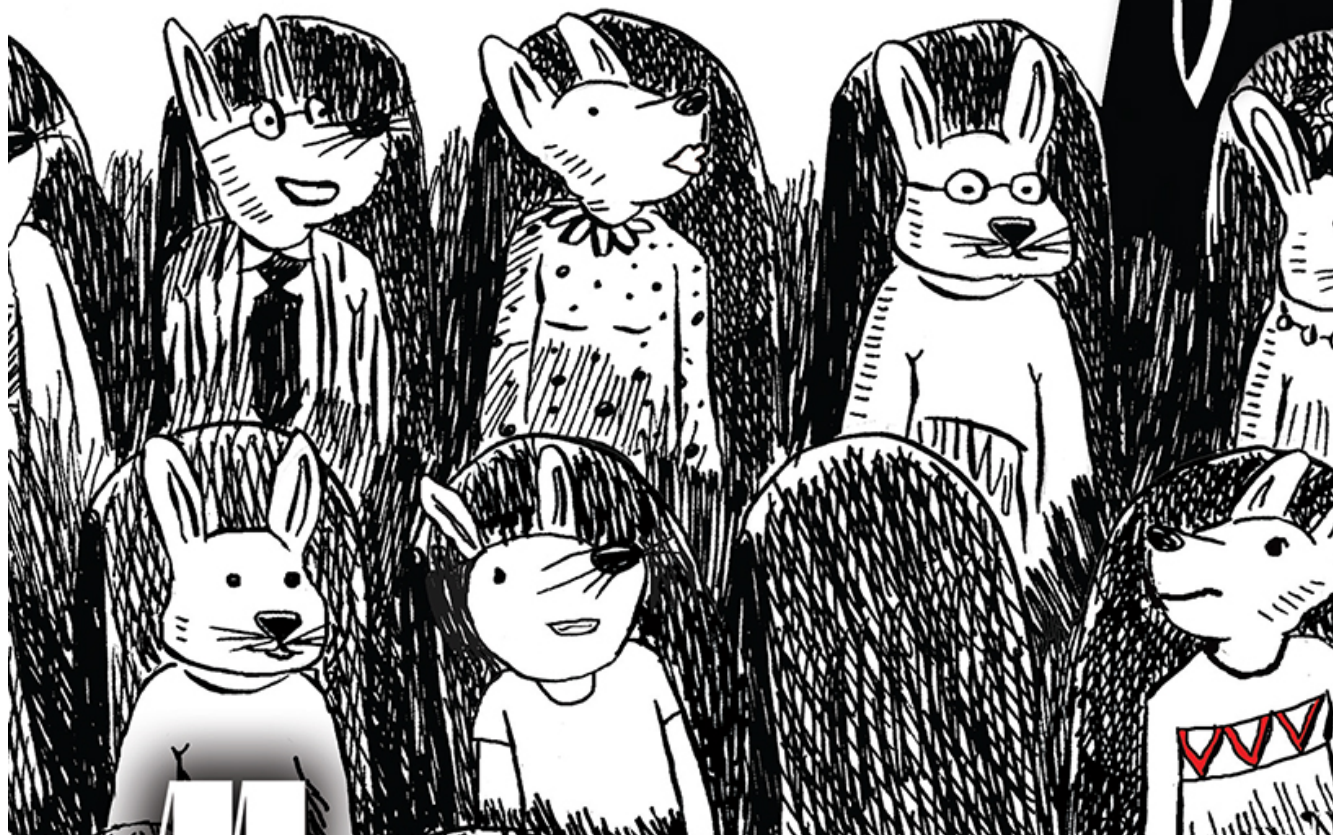


grokking

web application security

Malcolm McDonald

Foreword by Stuart McClure





Grokking Web Application Security

Malcolm McDonald

FOREWORD BY STUART MCCLURE

To comment go to [liveBook](#)



Manning

Shelter Island

For more information on this and other Manning titles go to
www.manning.com

Copyright

For online information and ordering of these and other Manning books, please visit www.manning.com. The publisher offers discounts on these books when ordered in quantity.

For more information, please contact

Special Sales Department
Manning Publications Co.
20 Baldwin Road
PO Box 761
Shelter Island, NY 11964
Email: orders@manning.com

©2024 by Manning Publications Co. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted, in any form or by means electronic, mechanical, photocopying, or otherwise, without prior written permission of the publisher.

Many of the designations used by manufacturers and sellers to distinguish their products are claimed as trademarks. Where those designations appear in the book, and Manning Publications was aware of a trademark claim, the designations have been printed in initial caps or all caps.

☺ Recognizing the importance of preserving what has been written, it is Manning's policy to have the books we publish printed on acid-free paper, and we exert our best efforts to that end. Recognizing also our responsibility to conserve the resources of our planet, Manning books are printed on paper that is at least 15 percent recycled and processed without the use of elemental chlorine.



Manning Publications Co.
20 Baldwin Road Technical
PO Box 761
Shelter Island, NY 11964

Development editor: Becky Whitney

Technical editor: Rajvardhan Oak

Review editor: Kishor Rit

Production editor: Deirdre Hiam

Copy editor: Keir Simpson

Proofreader: Katie Tennant

Technical proofreader: Karsten Strøbæk

Typesetter: Dennis Dalinnik

ISBN: 9781633438262

contents

Front matter

foreword

preface

acknowledgments

about this book

about the author

Part 1.

1 Know your enemy

Figuring out how hackers attack you (and why)
Surviving the fallout from getting hacked
Determining how paranoid you should be
Knowing where to start protecting yourself
Summary

2 Browser security

The parts of a browser
The JavaScript sandbox
Disk access
Cookies
Cross-site tracking
Summary

3 Encryption

The principles of encryption
Encryption keys
Encryption in transit
Encryption at rest
Integrity checking
Summary

4 Web server security

Validating input
Escaping output
Handling resources
Representation State Transfer (REST)
Defense in depth
The principle of least privilege
Summary

5 Security as a process

Using the four-eyes principle
Applying the principle of least privilege to processes
Automating everything you can
Not reinventing the wheel
Keeping audit trails
Writing code securely
Using tools to protect yourself
Owning your mistakes
Summary

Part 2.

6 Browser vulnerabilities

Cross-site scripting
Cross-site request forgery
Clickjacking
Cross-site script inclusion
Summary

7 Network vulnerabilities

Monster-in-the-middle vulnerabilities
Misdirection vulnerabilities
Certificate compromise
Stolen keys
Summary

8 Authentication vulnerabilities

- Brute-force attacks
- Single sign-on
- Strengthening your authentication
- Multifactor authentication
- Biometrics
- Storing credentials
- User enumeration
- Summary

9 Session vulnerabilities

- How sessions work
- Session hijacking
- Session tampering
- Summary

10 Authorization vulnerabilities

- Modeling authorization
- Designing authorization
- Implementing access control
- Testing authorization
- Spotting common authorization flaws
- Summary

11 Payload vulnerabilities

- Deserialization attacks
- XML vulnerabilities
- File upload vulnerabilities
- Path traversal
- Mass assignment
- Summary

12 Injection vulnerabilities

- Remote code execution
- SQL injection
- NoSQL injection
- LDAP injection
- Command injection
- CRLF injection
- Regex injection
- Summary

13 Vulnerabilities in third-party code

- Dependencies
- Farther down the stack
- Information leakage
- Insecure configuration
- Summary

14 Being an unwitting accomplice

- Server-side request forgery
- Email spoofing
- Open redirects
- Summary

15 What to do when you get hacked

- Knowing when you've been hacked
- Stopping an attack in progress
- Figuring out what went wrong
- Preventing the attack from happening again
- Communicating details about the incident to users
- Deescalating future attacks
- Summary

Index

foreword

I've hacked just about everything that's walked or crawled on this planet at one time or another. From my first hack of a fellow systems administrator's root password (authorized, of course) in 1989 to taking over an insulin pump and dispensing all the pump's insulin on the keynote stage of RSA 2012, I have made it my purpose to expose the world of the adversary—how an attacker thinks and works. After all, education is the final bastion of hope we have to prevent cyberattacks.

When I wrote my first book, *Hacking Exposed: Network Secrets and Solutions*, in 1999, I knew how important content on adversaries was to administrators. So I quickly cowrote one of the first textbooks on applying these hacking techniques to the new world of the internet: *Web Hacking: Attacks and Defense*, published in 2002. In that book, my coauthors and I used the same prescriptive formula to educate and kinetically teach defenders how to prevent cyberattacks on their web properties. Little did we know back then just how important software developers would be to the success or failure of hacks. In short, they are everything—because *100% of cyberattacks begin and end with code*.

Every piece of the internet runs on software. From network routers and switches to servers and endpoints to industrial control technologies, everything we use to share, communicate, and disseminate information is written in code. When a vulnerability is found, it is ultimately found in source code.

In this book, Malcolm delivers real-world examples of successful attacks and shows how to avoid being the next victim.

Two core problems exist in code that lead to security flaws: the presence of a security flaw and the lack of security features in code to prevent logic flaws. These conditions combine to cause 100% of cyberattacks, and only developers can truly prevent the attack at the root. Every other layer is simply window dressing. "Only you can prevent cyberattacks!" is the rallying cry for the developers of the world.

The only way we defenders can get ahead of the adversary once and for all is to solve the problem at its root: source code. Software engineers have to become security-savvy gurus who can predict how adversaries will use their code (or lack

of code) maliciously to exploit weaknesses. For this reason, only developers can fix the cybersecurity problem.

We've needed a book just like this one—simple, intuitive, and easy to grok; by developers for developers; speaking developers' language; offering advice and assistance in easily digestible nuggets. That is exactly what Malcolm achieves. He doesn't cover just the necessary bits of the code that developers produce, but also open source code. Additionally, he educates coders on managing a breach. These practical steps are critical for demystifying and destigmatizing developers and their role. If you could read only one book on cybersecurity, this book would be the one.

Grokking Web Application Security empowers all developers at all levels to understand the causes of cyberattacks and how to fix or mitigate those risks in a codebase. Malcolm clears up the murky waters of hacking and gives developers the confidence to attack the problems they find in code. In essence, *Grokking Web Application Security* should be considered the seminal primer on vulnerabilities in code. Every developer (and consequently every human) would benefit greatly from reading every single word.

—Stuart McClure, CEO of Qwiet AI, founding author of the *Hacking Exposed* book series

preface

Many moons ago (well, it wasn't *that* long ago, but the tech world moves so fast that programmer years are like dog years), I was put in charge of building and maintaining a system that would handle credit card information. Such systems have to meet the *Payment Card Industry Data Security Standards* (PCI DSS), which requires a grueling annual audit to ensure that you are meeting security requirements.

One of these requirements is to train your development team each year about the key software vulnerabilities that might affect such a system and how to protect against them. "Right," I thought. "This ought to be easy: the internet has so much freely accessible information about web application security."

It turned out that there was far too much to choose from. The internet is awash with *so much* information on web application security: detailed, disorganized, sometimes out of date or duplicative, and often aimed at cybersecurity professionals rather than working coders. I wanted something succinct and to the point. What are the most essential things to know if I could steal a day of every

Evaluation Only. Created with Aspose.Words. Copyright 2003-2026 Aspose Pty Ltd.

developer's time? And how best could I structure that information? I certainly didn't want to trap the whole development team in a conference room for 8 hours and make them sit through PowerPoint presentations of info they already mostly know. That frustration led me to create Hacksplaining.com and, eventually, to write this book.

Web application security is a curious subject area, in that every programmer (even fresh out of boot camp or with a recent computer science degree in hand) will have a fair knowledge of it, but we tend to feel (quite correctly) that we should know a little bit more. Doing your own research on the web can feel like walking into a disorganized library and picking up random texts, hoping to gain some good insights. Furthermore, nobody loves going to their boss and admitting that they have gaps in their knowledge, so we tend to be a little insecure about what we might not know.

With this book, I've tried to follow a few rules:

- Everything essential to know about web application security is contained within these pages.
- Everything here is useful to know.
- I've tried not to leave too many questions unanswered for the curious reader. Security advice on the internet tends to be along these lines: "Just use antisnarfing tokens to protect against the snarf-warbling vulnerability, or else a hacker will snarf your warbles." When I read this type of advice, I immediately begin to ask, "But how would you snarf someone's warbles? How would I get a job as a snarf warbler?" I have the sudden desire to know everything about snarf warbling.

To address this situation, where length permits, I've tried to show the tools hackers use, because (1) knowing about these tools gives you a real sense of the threat they pose, and (2) it's just plain fun to know some snarf-warbling secrets. Hackers tend to be like stage magicians in that they appear to have incredible powers, but once you know how a trick works, it tends to be disappointingly mundane in the mechanics yet amazingly impressive in the amount of preparation required to pull it off. Peeking behind the curtain should give the reader some motivation to plow through what can be somewhat-dry subject matter, as well as gain some useful background for assessing risks.

The result is (I hope) the book I would have wanted to read when I was starting as a developer, and one that I would delve into as an experienced developer to chase away the suspicion that I may have missed a few topics. (And I probably will delve into it, too; being a middle-aged programmer is an exercise in

refreshing your knowledge periodically.) It's certainly the book I would drop on the desk of the newest member of my development team, saying, "Read this when you get the chance. If you know all this already, that's a very good sign."

We programmers tend to learn by making mistakes; you can't truly call yourself an experienced developer until you've brought down production at least once, after all. But security mistakes *definitely* are *not* the type of thing you want to learn about from experience. If this book helps you prevent a *single* security mistake before it hits production, I would say that reading it has been worthwhile. I hope it proves to be worthwhile for you!

acknowledgments

I would like to thank my wife, Monica. Since we started dating, I've had approximately three different jobs, and she's been extremely patient as I've slugged through the writing process and grunted at my laptop. I promise not to write another book for a little while! She is also the one who bought me an Apple Pencil and suggested that I create my own illustrations, thus allowing me to live out the alternative life path where I went to art school and smoked clove cigarettes.

I need to thank my coauthor, our cat Haggis, who has been a constant writing companion and a sounding board for ideas. His insistence that I take frequent breaks to attend to his needs was probably healthy for me, although walking across the keyboard is probably not the most polite way to communicate those needs.

I also need to thank our dog, Beans, for warning me whenever anybody crossed the threshold of our house. It's difficult to know quite why he harbors such a grudge against our mail carrier, but it's refreshing to know that packages will never be dropped off unannounced.

I thank Mum and Dad for feeding me so much reading material as I grew up. And I'd like to thank my elder and younger brothers—Scott and Alasdair, respectively, who are the kindest and smartest people I know. (They are *both* very kind and very smart! But we are a competitive family, so these things need to be ranked.)

I thank my editor, Becky Whitney, for putting my sometimes-mangled grammar into approximately sensible order. There are so many words to choose among, and good writing is hard, so I endlessly remove and edit the same errors without a good editor. Which she is! I'd also like to thank my technical editor, Raj Oak, for catching the many and varied errors I committed when coming up with the code

samples and illustrations. I also thank the rest of the team at Manning: review editor Kishor Rit, production editor Deirdre Hiam, copy editor Keir Simpson, proofreader Katie Tennant, and typesetter Dennis Dalinnik.

Finally, I'd like to thank the (at the time of writing) reader review panel: Aboudou Samadou Sare, Adam Wan, Adrian Cucoş, Alexander Zenger, Aliaksandra Sankova, Bill Mitchell, Charles Chan, David Romano, Diana Carsona, Dieter Späth, Dr. Michael Piscatello, Ed Bacher, Emmanouil Chardalas, Giampiero granatella, Greg MacLean, Greg White, Ian De La Cruz, Jaehyun Yeom, Janet Jose, Jared Duncan, Javid Asgarov, Jorge Ezequiel Bo, Lev Veyde, Mario Pavlov, Maxim Volgin, Milorad Imbra, Najeeb Arif, Nathan McKinley-Pace, Patrick Regan, Paul Love, Peter Mahon, Ranjit Sahai, Samuel Bosch, Santosh Shanbhag, Sergio Britos, Tomasz Borek, and Zachary Manning. The quickest way for me to learn is to be wrong in public, and their generous feedback gave me room to correct my mistakes before the book was officially published. They also nudged me to cover certain topic areas I hadn't considered, which improved the book immeasurably.

about this book

Grokking Web Application Security was written to be a comprehensive overview of every aspect of web application security. The book covers all the major security principles a modern web developer should know and all the vulnerabilities they are likely to encounter. There are two ways to read this book, depending on how you absorb knowledge. If you are patient, read it from cover to cover, and you will find that the topics gradually reveal the world of application security. If you are impatient (like me!), dive into a chapter that looks interesting; you will find that it references related topics that pull you in different directions.

Who should read this book

This book is for anyone who writes web applications and feels that they should know more about web application security. That includes first-time coders who are looking for a map of the territory and experienced hands who want to brush up their knowledge. The code samples are in a variety of languages, chosen to illustrate various principles and vulnerabilities.

How this book is organized: A road map

This document was truncated here because it was created in the Evaluation Mode.